

## Marco integrativo GQM + PRAGMATIC aplicado a los indicadores OCTAVE nacionales

Versión 1.0 – Cómo pasar de los objetivos estratégicos de país a las métricas técnicas, sin perderse por el camino ni coleccionar KPIs inútiles.

### 1. Propósito del marco integrativo

Este documento define un **marco integrativo GQM + PRAGMATIC** aplicado a los indicadores OCTAVE propuestos para el nivel nacional en España (servicios esenciales, ENS, incidentes INCIBE, etc.). El objetivo es asegurar:

- Trazabilidad vertical: desde objetivos estratégicos nacionales (resiliencia de servicios esenciales, cumplimiento ENS/NIS2, protección de derechos) hasta métricas concretas que se alimentan de datos técnicos.[web:84][web:90]
- Calidad de las métricas: cada métrica se evalúa con los nueve criterios PRAGMATIC (Predictiva, Relevante, Accionable, Genuina, Significativa, Precisa, Oportuna, Independiente, Rentable), evitando la proliferación de indicadores decorativos.[web:83][web:86][web:89]
- Coherencia metodológica: uso disciplinado de GQM (Goal–Question–Metric) para derivar, a partir de cada objetivo, las preguntas y métricas asociadas.[web:79][web:82][web:88]

### 2. Recordatorio breve de GQM y PRAGMATIC

#### 2.1. GQM (Goal–Question–Metric)

GQM propone derivar métricas en tres pasos:

1. Goal (Objetivo): definir, para un objeto concreto (por ejemplo, un servicio esencial, el sistema nacional ENS o el programa de respuesta a incidentes), el propósito de la medición, el punto de vista y el contexto.[web:79][web:82][web:85]
2. Question (Pregunta): formular preguntas que, si pudieran responderse, indicarían hasta qué punto se está alcanzando el objetivo.
3. Metric (Métrica): seleccionar o diseñar métricas cuantitativas o cualitativas que permitan responder empíricamente a las preguntas.

La fortaleza de GQM está en que **ninguna métrica aparece “porque sí”**: todas son hijas de un objetivo y una pregunta explícitos.[web:79][web:82][web:91]

#### 2.2. PRAGMATIC como metamétrica

El enfoque PRAGMATIC, propuesto por Brotby e Hinson, define nueve criterios para evaluar la **calidad y utilidad de cada métrica**: [web:80][web:83][web:86][web:89]

- P – Predictive (Predictiva): ¿ayuda a anticipar futuros estados o riesgos?
- R – Relevant (Relevante): ¿es pertinente para los objetivos y decisiones del público objetivo?
- A – Actionable (Accionable): ¿sugiere claramente acciones posibles o cambios?
- G – Genuine (Genuina): ¿es honesta, difícil de manipular y refleja la realidad?
- M – Meaningful (Significativa): ¿es comprensible e interpretable sin exégesis heroicas?
- A – Accurate (Precisa): ¿es suficientemente precisa y fiable para su propósito?
- T – Timely (Oportuna): ¿está disponible con la frecuencia y latencia adecuadas?
- I – Independent (Independiente): ¿no está excesivamente condicionada por intereses o sesgos particulares?
- C – Cheap (Rentable): ¿el coste de obtenerla es razonable frente al valor que aporta?

PRAGMATIC actúa como una **metamétrica**: no mide seguridad, mide la calidad de cómo medimos la seguridad.[web:83][web:86][web:92]

### 3. Conjunto de indicadores OCTAVE nacionales

Recordamos los indicadores propuestos en el informe OCTAVE nacional:

4. Inventario de servicios esenciales digitalizados.
5. Cobertura ENS en administraciones.
6. Protección de datos personales.
7. Incidentes por sector.
8. Tendencia de incidentes nacionales.
9. Amenazas contra disponibilidad.
10. Sistemas vulnerables detectados.
11. Exposición de servicios esenciales.
12. Brechas de capacidad.
13. Gobernanza y liderazgo.
14. Capacidad de respuesta nacional.
15. Cultura y formación.
16. Pérdidas económicas estimadas.
17. Continuidad de servicios esenciales.
18. Confianza digital.

Para cada uno se definirá una cadena QQM y se evaluará su calidad mediante PRAGMATIC.

### 4. Patrón QQM aplicado a cada indicador

A continuación se ofrece el patrón QQM genérico que se aplica repetidamente a cada indicador.

#### 4.1. Plantilla GQM

- Objetivo (G): [Mejorar / Monitorizar / Comparar] la [característica] de [objeto] desde el punto de vista de [stakeholder] en el contexto de [país/sector/periodo].
- Preguntas (Q): 3–5 preguntas que aterrizan el objetivo en aspectos observables.
- Métricas (M): 1–3 métricas asociadas a cada pregunta, con definición de fórmula, unidad, fuente de datos y frecuencia.

#### 4.2. Ejemplo ilustrativo: “Inventario de servicios esenciales digitalizados”

- Objetivo G1: Evaluar hasta qué punto los servicios esenciales del país dependen de sistemas TIC identificados y gestionados, desde el punto de vista de los responsables nacionales de ciberseguridad, en el contexto del cumplimiento ENS/NIS2.
- Preguntas G1-Q:
- Q1.1: ¿Qué porcentaje de servicios esenciales tienen identificados sus activos TIC críticos?
- Q1.2: ¿Hasta qué punto se mantienen actualizados esos inventarios?
- Q1.3: ¿Se vinculan los inventarios con la gestión de riesgos y continuidad?
- Métricas G1-M:
- M1.1:  $\%SE\_con\_inventario = (N^{\circ} \text{ de servicios esenciales con inventario formal} / N^{\circ} \text{ total de servicios esenciales identificados}) \times 100$ .
- M1.2:  $\%Inventarios\_actualizados = (N^{\circ} \text{ de inventarios revisados en los últimos 12 meses} / N^{\circ} \text{ total de inventarios}) \times 100$ .
- M1.3:  $\%Inventarios\_vinculados\_riesgo = (N^{\circ} \text{ de inventarios integrados en el sistema de gestión de riesgos} / N^{\circ} \text{ total de inventarios}) \times 100$ .

Este esquema se replicará para cada indicador, sustituyendo el objetivo, las preguntas y las métricas específicas.

### 5. Aplicación GQM a los 15 indicadores (resumen)

En este marco integrativo, se asume la siguiente estructura (desarrollada en detalle en la matriz PRAGMATIC):

19. Inventario de servicios esenciales digitalizados
20. Objetivo: evaluar la identificación y gestión de activos críticos nacionales (OCTAVE – activos).
21. Preguntas: cobertura de inventarios, actualización, vinculación con análisis de riesgo y continuidad.
22.  
Métricas: porcentajes de servicios con inventario, inventarios actualizados, inventarios integrados en gestión de riesgos.
23.  
Cobertura ENS en administraciones
24. Objetivo: medir el grado de implantación del ENS y, por extensión, la madurez de seguridad en el sector público.[web:60][web:63][web:90]
25. Preguntas: porcentaje de organismos categorizados, sistemas auditados, nivel medio de cumplimiento.
26.  
Métricas: % de organismos con sistemas categorizados, % de sistemas ENS certificados, promedio de nivel de madurez ENS.
27.  
Protección de datos personales
28. Objetivo: monitorizar la protección de bases de datos de alto valor (salud, hacienda, justicia) desde la perspectiva RGPD/ENS.[web:84][web:87]
29. Preguntas: cobertura de EIPD, medidas de seguridad específicas, incidentes de brecha de datos.
30.  
Métricas: % de bases de datos críticas con EIPD, nº de brechas notificadas por 100.000 registros, etc.
31.  
Incidentes por sector
32. Objetivo: conocer la distribución sectorial del riesgo materializado (OCTAVE – amenazas) usando datos de INCIBE/CCN-CERT.[web:87]
33. Preguntas: frecuencia por sector, tipo de incidente, tendencia.
34.  
Métricas: incidentes por sector y año, tasa de incidentes por 1.000 organizaciones, etc.
35.  
Tendencia de incidentes nacionales
36. Objetivo: evaluar la evolución del nivel de exposición general del país.
37. Preguntas: variación interanual, cambios por tipo de incidente.

38.

Métricas: % de incremento/decremento anual, tasa de crecimiento por categoría.

39.

Amenazas contra disponibilidad

40. Objetivo: monitorizar la prevalencia de ataques a la disponibilidad de servicios esenciales.

41. Preguntas: proporción de incidentes de disponibilidad, duración media, sectores afectados.

42.

Métricas: % de incidentes clasificados como ataques a disponibilidad, horas de interrupción por año.

43.

Sistemas vulnerables detectados

44. Objetivo: medir la superficie de exposición técnica a través de sistemas vulnerables relevantes.

45. Preguntas: densidad de sistemas vulnerables, criticidad de vulnerabilidades, tiempo de exposición.

46.

Métricas: nº de sistemas vulnerables por millón de habitantes, % de vulnerabilidades críticas abiertas > X días.

47.

Exposición de servicios esenciales

48. Objetivo: evaluar la exposición específica de operadores esenciales a vulnerabilidades críticas.

49. Preguntas: % de sistemas de operadores esenciales con vulnerabilidades críticas, cobertura de parches.

50.

Métricas: % de sistemas críticos con vulnerabilidades críticas sin parchear en plazo, etc.

51.

Brechas de capacidad

52. Objetivo: identificar gaps estructurales de capacidad (recursos, procesos, madurez) en sectores clave.

53. Preguntas: falta de personal, baja madurez ENS/NIS2, sectores en zona de riesgo según ENISA NIS360.[web:19][web:21]

54.

Métricas: ratio de profesionales de ciberseguridad por 10.000 empleados TIC, porcentaje de sectores en zona de riesgo, etc.

55.

### Gobernanza y liderazgo

Objetivo: medir la existencia y efectividad del liderazgo político y de gobernanza de ciberseguridad (CNCS, estrategias, comités).[web:81][web:87]

Preguntas: existencia de estrategias, planes, comités; frecuencia de reuniones; accountability.

Métricas: nº de reuniones anuales de órganos de ciberseguridad, % de acciones del plan nacional ejecutadas, etc.

56.

### Capacidad de respuesta nacional

Objetivo: evaluar la capacidad operativa de CSIRTs nacionales y mecanismos de respuesta.[web:81][web:87]

Preguntas: tiempos de respuesta, cobertura sectorial, coordinación.

Métricas: tiempo medio de respuesta a incidentes significativos, nº de ejercicios conjuntos por año.

57.

### Cultura y formación

Objetivo: medir el nivel de concienciación y formación en ciberseguridad de ciudadanía, empresas y administraciones.[web:19][web:21]

Preguntas: % de organizaciones con programas de formación, alcance de campañas nacionales.

Métricas: % de organizaciones que realizan formación anual, nº de participantes en campañas, etc.

58.

### Pérdidas económicas estimadas

Objetivo: estimar el impacto económico agregado de los ciberincidentes a nivel país.

Preguntas: coste medio por incidente, pérdidas totales por sector.

Métricas: pérdidas agregadas estimadas por año, % del PIB afectado.

59.

#### Continuidad de servicios esenciales

Objetivo: evaluar la resiliencia en la prestación de servicios esenciales frente a incidentes.

Preguntas: nº de interrupciones significativas por año, duración media, impacto ciudadano.

Métricas: nº de interrupciones de servicios esenciales debidas a ciberincidentes, horas de indisponibilidad por 100.000 habitantes.

60.

#### Confianza digital

Objetivo: medir la confianza de ciudadanos y empresas en los servicios digitales y la ciberseguridad nacional.[web:51][web:19]

Preguntas: percepción de seguridad, disposición a utilizar servicios digitales críticos.

Métricas: % de ciudadanos que declaran confiar en servicios digitales, % de empresas que ven la ciberseguridad como habilitadora de negocio.

Métricas: porcentajes de servicios con inventario, inventarios actualizados, inventarios integrados en gestión de riesgos.

#### **Cobertura ENS en administraciones**

Métricas: % de organismos con sistemas categorizados, % de sistemas ENS certificados, promedio de nivel de madurez ENS.

#### **Protección de datos personales**

Métricas: % de bases de datos críticas con EIPD, nº de brechas notificadas por 100.000 registros, etc.

#### **Incidentes por sector**

Métricas: incidentes por sector y año, tasa de incidentes por 1.000 organizaciones, etc.

#### **Tendencia de incidentes nacionales**

Métricas: % de incremento/decremento anual, tasa de crecimiento por categoría.

#### **Amenazas contra disponibilidad**

Métricas: % de incidentes clasificados como ataques a disponibilidad, horas de interrupción por año.

#### **Sistemas vulnerables detectados**

Métricas: nº de sistemas vulnerables por millón de habitantes, % de vulnerabilidades críticas abiertas > X días.

### **Exposición de servicios esenciales**

Métricas: % de sistemas críticos con vulnerabilidades críticas sin parchear en plazo, etc.

### **Brechas de capacidad**

Métricas: ratio de profesionales de ciberseguridad por 10.000 empleados TIC, porcentaje de sectores en zona de riesgo, etc.

### **Gobernanza y liderazgo**

- Objetivo: medir la existencia y efectividad del liderazgo político y de gobernanza de ciberseguridad (CNCS, estrategias, comités).[web:81][web:87]
- Preguntas: existencia de estrategias, planes, comités; frecuencia de reuniones; accountability.
- Métricas: nº de reuniones anuales de órganos de ciberseguridad, % de acciones del plan nacional ejecutadas, etc.

### **Capacidad de respuesta nacional**

- Objetivo: evaluar la capacidad operativa de CSIRTs nacionales y mecanismos de respuesta.[web:81][web:87]
- Preguntas: tiempos de respuesta, cobertura sectorial, coordinación.
- Métricas: tiempo medio de respuesta a incidentes significativos, nº de ejercicios conjuntos por año.

### **Cultura y formación**

- Objetivo: medir el nivel de concienciación y formación en ciberseguridad de ciudadanía, empresas y administraciones.[web:19][web:21]
- Preguntas: % de organizaciones con programas de formación, alcance de campañas nacionales.
- Métricas: % de organizaciones que realizan formación anual, nº de participantes en campañas, etc.

### **Pérdidas económicas estimadas**

- Objetivo: estimar el impacto económico agregado de los ciberincidentes a nivel país.
- Preguntas: coste medio por incidente, pérdidas totales por sector.
- Métricas: pérdidas agregadas estimadas por año, % del PIB afectado.

### **Continuidad de servicios esenciales**

- Objetivo: evaluar la resiliencia en la prestación de servicios esenciales frente a incidentes.
- Preguntas: nº de interrupciones significativas por año, duración media, impacto ciudadano.
- Métricas: nº de interrupciones de servicios esenciales debidas a ciberincidentes, horas de indisponibilidad por 100.000 habitantes.



## Confianza digital

- **Objetivo:** medir la confianza de ciudadanos y empresas en los servicios digitales y la ciberseguridad nacional.[web:51][web:19]
- **Preguntas:** percepción de seguridad, disposición a utilizar servicios digitales críticos.
- **Métricas:** % de ciudadanos que declaran confiar en servicios digitales, % de empresas que ven la ciberseguridad como habilitadora de negocio.

El detalle de las preguntas y métricas específicas, con su evaluación PRAGMATIC, se desarrolla en la “Matriz de Evaluación PRAGMATIC Completa”.

## 6. Integración práctica en el sistema nacional de indicadores

- El marco QOM se utiliza para documentar formalmente, por cada indicador, el objetivo, las preguntas y las métricas asociadas.
- PRAGMATIC se aplica para priorizar: métricas con baja puntuación global (por ejemplo, porque son poco predictivas o no accionables) se revisan o eliminan.
- El resultado es un catálogo curado de métricas OCTAVE nacionales, alineadas con ENS, NIS2 y los marcos internacionales de medición (ENISA, OCDE, GCI, NCSI).[web:19][web:21][web:51][web:26][web:22]

Este marco permite explicar, sin sonrojo, por qué se mide lo que se mide, para qué sirve y cómo se conecta con las decisiones estratégicas de país. Que, al fin y al cabo, es el mínimo exigible a cualquier indicador que aspire a aparecer en un consejo de ministros o en un informe anual sin provocar miradas perdidas.